

Measuring the Defenders: A Layer-Aware, Framework-Mapped Benchmark for Model Context Protocol Security Proxies

Gowthaman Arumugam
Independent Researcher
agowthaman90@gmail.com

Version 0.4 · July 2026

Preprint. Code, data, and a public leaderboard are openly available (see §10).

Abstract

The Model Context Protocol (MCP) has become a common way to connect large-language-model (LLM) agents to external tools and data, and a substantial 2025–2026 literature now documents its attack surface. Existing security benchmarks for MCP measure how well an *LLM agent resists* attacks. None, to our knowledge, measure how well a *defensive proxy or gateway covers* that attack surface, and none map their results to the governance frameworks organizations actually use — the NIST AI Risk Management Framework (AI RMF), the NSA MCP Security guidance, and the OWASP Top 10 for LLM and Agentic Applications. We present two artifacts to fill this gap: (1) a **threat–control crosswalk** of 24 MCP attack vectors mapped to architectural layer, STRIDE class, NIST AI RMF function, NSA recommendation area, and OWASP category; and (2) an open, vendor-neutral **defense-side benchmark** that runs a candidate MCP security proxy against a corpus of attack fixtures with matched benign controls, and scores its coverage using the crosswalk as a rubric. Each tool is driven through its *real* code, not a mock. We evaluate three open-source proxies (`mcp-bastion`, `mcp-firewall`, `pipelock`) plus a null baseline over 35 test cases. The strongest proxy reaches **63% weighted coverage (15.0 of 24 vectors; 11 enforced)**, and across all three tools **19 of 24 vectors are covered by at least one tool while 5 are covered by none** — the registry/supply-chain surface, OS-isolation-dependent vectors, and several semantic vectors. All results carry **zero false positives** against matched benign controls. We argue this is direct, quantified evidence that a runtime proxy alone is insufficient and that defense-in-depth spanning *distinct mechanism classes* (proxy, cryptographic attestation, OS isolation) is required. We further show the benchmark can *guide* a defender’s development: over the study, `mcp-bastion`’s measured coverage rose from 9% to 63% as gaps the benchmark surfaced were fixed and re-verified — including two attacks first published in June 2026, one of which (ShareLock) no measured tool covered until a cross-tool correlation check was added, and an evasion-normalization stage that lifted the reference proxy’s robustness to obfuscated payloads from 1/3 to 3/3. A matched benign-control design, a “measure only what the tool inspects at runtime” integrity rule, and an automated benchmark-regression gate keep the results honest and reproducible.

Keywords: Model Context Protocol; MCP security; LLM agents; agentic AI; security benchmark; tool poisoning; prompt injection; defense-in-depth; NIST AI RMF; NSA MCP Security; OWASP LLM Top 10; OWASP Agentic Top 10.

1 Introduction

MCP standardizes how an LLM agent discovers and calls external “tools” exposed by “servers” [2]. Its rapid adoption across consumer and enterprise agents has been accompanied, in 2025–2026, by a dense body of security research: systematization-of-knowledge papers, formal threat taxonomies, attack benchmarks, and cryptographic attestation proposals (§2). This work establishes *what can go wrong*.

A practical question remains under-addressed: **given a defensive tool that sits in front of MCP servers — a proxy, gateway, or scanner — how much of the known attack surface does it actually cover?** Answering it well requires three things that, individually, exist in the literature but have not been combined:

1. a **shared taxonomy** of MCP attack vectors;
2. a mapping from those vectors to the **governance frameworks** (NIST AI RMF, NSA, OWASP) that security and procurement teams reason in; and
3. an **executable, reproducible** way to test a defender and report coverage.

We contribute all three, plus an empirical study. Concretely:

- **A threat–control crosswalk** (§3): 24 MCP attack vectors, each mapped to one of six architectural layers, a STRIDE class, NIST AI RMF functions, NSA MCP Security recommendation areas, and OWASP LLM-2025 and Agentic-2026 categories. Published as open, versioned, machine-readable data.
- **A defense-side benchmark** (§4): for each vector, one or more attack *fixtures* paired with a near-identical *benign control*; a small *adapter* per tool that drives the tool’s real detection code; and a scorer that reports coverage per layer and per framework.
- **An empirical evaluation** (§5–6) of three open-source proxies and a null baseline, yielding a complementarity finding: no single tool suffices.
- **A benchmark-guided development study** (§7): using the benchmark’s own gap reports to drive a reference proxy from 9% to 63% coverage at zero false positives, and an automated regression gate that keeps the loop honest.

Our aim is not to rank products but to map coverage, expose gaps, and provide reusable infrastructure that tracks a fast-moving threat surface.

2 Related Work

The recent MCP-security preprints below propose taxonomies that are their authors’ own constructs; we cite them as *proposed by*, not as established consensus, and coverage statistics quoted from any single paper reflect that paper’s surveyed set.

Threat taxonomies. Recent work systematizes MCP threats through several lenses: an SoK separating adversarial security threats (indirect prompt injection, tool poisoning) from epistemic safety hazards across the Resources/Prompts/Tools primitives [6]; a formal framework of seven threat categories and 23 attack vectors grounded in a large tool corpus [1]; a STRIDE/DREAD model over five MCP components that identifies tool poisoning as the most impactful client-side vulnerability [7]; and a defense-placement taxonomy classifying defenses by the layer that enforces

them, which finds protection “uneven and predominantly tool-centric” with weak transport, host-orchestration, and supply-chain coverage [16]. Our crosswalk reuses these vector families but adds the framework mapping none of them provides.

Attack-side benchmarks. MSB [21] (12 attacks, ~2,000 instances, real MCP execution) measures the resistance of the *LLM agent* across the tool-use pipeline; MCPTox [20] scopes to tool poisoning; AgentDefense-Bench [17] aggregates datasets into MCP JSON-RPC test cases; MCP-Bench [19] measures agent *capability*, not security. All measure the agent (or the model), not a *defensive proxy*. Ours measures the defender, on the full mapped surface, and reports coverage crosswalked to NIST/NSA/OWASP — which we could not find in any surveyed benchmark.

Attestation and provenance. ETDI [5] proposes signed, versioned tool definitions; a Trustworthy MCP Registry blueprint [10] composes existing standards (well-known URIs, Sigstore, JSON Canonicalization + JWS) for provenance and runtime integrity, noting the official MCP registry remains an unverified pointer architecture. These are complementary to our benchmark; a future attestation-conformance suite (§9) would test them.

New attacks (June 2026). Two attacks published after our v0.2 rubric was frozen are incorporated here: mid-session tool injection (MSTI), in which malicious tools are injected into an active session — through tool hijacking (modifying visible tools) or tool framing (manipulating tool metadata) [8]; and ShareLock, a stealthy multi-tool threshold poisoning attack that uses a threshold-sharing scheme to split a payload across several tools so no single description looks malicious [9].

Scanners and gateways. Practitioner tools include Invariant Labs’ MCP-Scan (since acquired by Snyk and now a cloud-gated scanner [18]), gateway products, and the proxies we evaluate here. Our benchmark scores locally-deterministic defenders and treats cloud-model defenders as observable-but-not-reproducibly-scoreable (§4.4).

3 The Threat–Control Crosswalk

The crosswalk is the benchmark’s rubric and a standalone artifact. It enumerates 24 MCP attack vectors consolidated from the taxonomies in §2, and maps each to: an **architectural layer** (host-orchestration, client, transport, server, tool, registry-supply-chain), following the defense-placement view of Rostamzadeh et al. [16]; a **STRIDE** class [11]; **NIST AI RMF** function(s) (Govern, Map, Measure, Manage) [12]; an **NSA MCP Security** recommendation area (Authentication & Access Control, Monitoring & Logging, Data Classification & Segmentation, Runtime Controls) [13]; and **OWASP Top 10** categories for LLM (2025, LLM01–LLM10) [15] and Agentic (2026, ASI01–ASI10) [14] applications. Table 1 lists the vectors and their primary layer; the full mapping, including STRIDE and all framework codes, is published as machine-readable data (`rubric/crosswalk.json`, CC-BY-4.0).

The mappings are indicative and reviewable, not a certification — we invite community correction, which is itself a goal of publishing the rubric openly.

Table 1: The 24 MCP attack vectors and their primary architectural layer.

#	Vector	Layer	#	Vector	Layer
1	Tool poisoning	tool	13	Sandbox escape	server
2	Tool shadowing / name collision	client	14	Schema / validation bypass	server
3	Rug pull (definition mutation)	tool	15	Man-in-the-middle (transport)	transport
4	Out-of-scope parameter injection	tool	16	DNS rebinding (local servers)	transport
5	Prompt injection via tool results	tool	17	Server impersonation	reg.-supply
6	Indirect / retrieval injection	tool	18	Excessive permission / escalation	host-orch.
7	Cross-tool exfiltration	client	19	Credential / token theft	host-orch.
8	Tool-transfer / cross-server chaining	host-orch.	20	Consent fatigue / over-broad grants	client
9	False-error escalation	tool	21	Command injection	server
10	Package / name squatting	reg.-supply	22	System-prompt / context leakage	client
11	Supply-chain poisoning	reg.-supply	23	Mid-session tool injection (MSTI)	client
12	Configuration drift	server	24	Multi-tool split poisoning (ShareLock)	tool

4 Benchmark Methodology

4.1 Design

For each vector the corpus contains one or more **test cases**. A test case is a static JSON object with: a *malicious fixture* (the attack, as data — a tool definition, tool call, tool result, registry entry, call sequence, or scenario), a near-identical *benign control*, the *expected* defender behavior (**detect/enforce**), and a *provenance* note. Fixtures are static data, never live exploits; attacker hosts use reserved names (`attacker.example`; the cloud-metadata address `169.254.169.254` appears only as an SSRF *target* in data, never contacted).

4.2 Adapters and the runtime-integrity rule

Each evaluated tool provides a thin **adapter** exposing `assess(input) → {detect, enforce}`. The runner calls it once on the malicious fixture and once on the benign control. Adapters drive the tool’s *real* code (importing the proxy’s detection functions, or invoking its CLI/SDK with a committed configuration). A central rule keeps scores honest:

Report only what the tool actually inspects at runtime — never what its rules could match if pointed at data the tool never sees.

For example, a proxy that inspects tool *definitions* but not tool *results* returns “not detected” for result-borne attacks, even if its text rules would match the result string in isolation. This measures deployed behavior, not theoretical capability.

4.3 Scoring

Per test case: if the malicious fixture is not flagged, the vector scores **none**; if it is flagged but the benign control is *also* flagged, the vector scores **none** and is marked a **false positive**; if the

malicious fixture is flagged and the benign control is clean, the vector scores **detect** (warn) or **enforce** (block). A vector’s level is the best across its test cases. Weighted coverage assigns $\text{enforce} = 1.0$, $\text{detect} = 0.5$, $\text{none} = 0$, over 24 vectors. The matched benign control is essential: without it, a tool that flags everything would score perfectly while being useless.

4.4 Reproducibility rule

A defender is **scored** only if its detection logic runs *locally and deterministically*. Tools that delegate detection to a proprietary cloud model can be *observed* but not reproducibly *scored*, since their verdicts depend on a black box that can change between runs. This excludes, e.g., the cloud-gated Snyk agent-scan; it includes the three proxies below.

5 Experimental Setup

We evaluate four adapters over a 35-case corpus (24 base cases + 6 realistic “v2” cases for fairness + 3 “v3” evasion-robustness cases + 2 added with new vectors; see §7).

Table 2: Evaluated tools. Each is pinned to a released version and configured with its own committed recommended policy for reproducibility.

Tool	Class / License	How driven
null-baseline	control / —	returns “not detected” for all inputs
mcp-bastion	runtime proxy / Apache-2.0	imports real detection: <code>scanTool</code> , <code>scanText</code> (with evasion normalization), <code>scanToolSet</code> , <code>scanCallSequence</code> (cross-server taint), <code>validateArguments</code> , <code>checkCommandInjection</code> , <code>checkConfigDrift</code> , <code>checkServerIdentity</code> , <code>redactSecrets</code> , transport/origin checks; run under its default balanced enforcement profile
mcp-firewall	runtime proxy (Python) / AGPL-3.0	real SDK (<code>Gateway.check</code> / <code>scan_response</code>) with a committed config
pipelock	egress firewall (Go) / Apache-2.0 core	real scanners via <code>explain -json</code> (URL/egress) and <code>mcp scan</code> (response injection), offline and deterministic

For AGPL/other licensed tools we *run* the tool to benchmark it and report scores; we do not redistribute their code.

6 Results

Table 3: Verified coverage (35 cases; weighted over 24 vectors). Weighted = $\text{enforce} + 0.5 \cdot \text{detect}$.

Tool	Class	Weighted	enforce	detect	none	False pos.
mcp-bastion	runtime proxy	63% (15.0/24)	11	8	5	0 / 35
mcp-firewall	runtime proxy	13% (3.0/24)	3	0	21	0 / 35
pipelock	egress firewall	10% (2.5/24)	1	3	20	0 / 35
null-baseline	control	0%	0	0	24	0 / 35

Table 4: Per-vector coverage. **E**=enforce (blocks), **D**=detect (warns), **.**=not covered.

Vector (primary layer)	bastion	firewall	pipelock	null
Tool poisoning (tool)	D	.	.	.
Tool shadowing / name collision (client)	D	.	.	.
Rug pull / definition mutation (tool)	E	.	.	.
Out-of-scope parameter injection (tool)	E	.	.	.
Prompt injection via tool results (tool)	D	.	D	.
Indirect / retrieval injection (tool)	E	E	D	.
Cross-tool exfiltration / confused deputy (client)	E	E	E	.
Tool-transfer / cross-server chaining (host-orch.)	E	.	.	.
False-error escalation (tool)	.	.	.	.
Package / name squatting (reg.-supply)	.	.	.	.
Supply-chain poisoning / provenance gap (reg.-supply)	.	.	.	.
Configuration drift (server)	D	.	.	.
Sandbox escape (server)	.	.	.	.
Schema / validation bypass (server)	E	.	.	.
Man-in-the-middle / transport (transport)	D	.	.	.
DNS rebinding, local servers (transport)	E	.	.	.
Server impersonation / identity spoofing (reg.-supply)	E	.	.	.
Excessive permission / escalation (host-orch.)	D	.	.	.
Credential / token theft via passthrough (host-orch.)	E	E	.	.
Consent fatigue / over-broad grants (client)	.	.	.	.
Command injection in tool execution (server)	E	.	.	.
System-prompt / context leakage (client)	D	.	D	.
Mid-session tool injection — MSTI (client)	E	.	.	.
Multi-tool split poisoning — ShareLock (tool)	D	.	.	.

A proxy can cover most of, but not all, the surface. `mcp-bastion`, the broadest tool, spans the definition, response, argument, transport, egress/least-privilege, cross-server, and server-identity layers. Under its default `balanced` enforcement profile, the deterministic, low-false-positive checks (rug-pull, server-identity change, argument/schema and command-injection, cross-server data flow) *block* rather than merely warn, giving 11 enforced vectors. `mcp-firewall` and `pipelock` add *enforcement* on the call and egress layers (deny/redact/SSRF-block); `pipelock` additionally detects response-borne prompt injection via its MCP-response scanner. The full per-vector picture is in Table 4.

Defense-in-depth across mechanism classes is required. Even with the strongest proxy at 63%, and across all three tools, **19 of 24 vectors are covered by at least one tool; 5 are covered by none**: false-error escalation, package/name squatting, provenance-gap supply-chain poisoning, sandbox escape, and consent fatigue. These are not addressable by *any* content-scanning runtime proxy; they require different mechanisms — cryptographic attestation and a verified registry, OS sandboxing, and client-side consent controls. A proxy is necessary but not sufficient. Nineteen vectors are caught by some tool yet missed by others, direct evidence that no single defender suffices.

Two June-2026 attacks. MSTI is caught by `mcp-bastion`’s definition pinning, which re-hashes a tool on each use and *enforces* on a post-approval change; neither other tool covers it. ShareLock — a payload split across several tools — was covered by *no* measured tool until we added **cross-tool correlation**: because a proxy sees a server’s whole tool set, it scans the combined descriptions and flags coordinated `share/checksum`-style staging metadata across tools. It now detects ShareLock; the other tools, which scan one tool at a time, still miss it. This is a staging-signal heuristic, not a cryptographic defeat of threshold secret-sharing (§8).

Evasion robustness. The corpus includes three obfuscated variants of known attacks (Table 5). Before this study’s evasion-normalization work, the reference proxy caught only the zero-width variant. After adding a normalization stage (Unicode NFKC, homoglyph folding, and base64 decode-and-rescan), `mcp-bastion` catches all three; `pipelock` catches the homoglyph and base64 variants via its own normalization but misses zero-width; `mcp-firewall` catches none. No single tool other than the normalized reference proxy survives all three.

Table 5: Evasion robustness: which tools still detect an obfuscated variant of a known attack.

Attack (encoding)	bastion	firewall	pipelock	null
Zero-width / bidi-control characters	D	.	.	.
Cyrillic homoglyph substitution	D	.	D	.
Base64-wrapped payload	D	.	D	.
Robustness (detected / 3)	3/3	0/3	2/3	0/3

Zero false positives. No tool flagged any benign control, across all 35 cases and every feature iteration. Enforcement level (block vs. warn) does not change *whether* a control is flagged, so promoting deterministic checks to blocking preserves the zero-false-positive property.

7 Discussion

Benchmark-guided improvement (9%→63%). The benchmark did more than measure the reference proxy; it drove its development. Starting from tool-definition scanning only (9%), each round of proxy-native hardening was re-measured at zero false positives (Table 6). The benchmark identified concrete, layer-specific gaps, verified each fix, and then defined the proxy’s ceiling: the five remaining vectors are architecturally outside a content-scanning proxy’s reach.

Table 6: Benchmark-guided development of the reference proxy. The rubric expanded from 22 to 24 vectors when the two June-2026 attacks were added, so early and late percentages are over slightly different denominators; all steps were re-verified at zero false positives.

Stage	Capability added	Coverage
baseline	tool-definition scanning only	9%
response scanning	result-borne injection, retrieval injection, leakage	18%
argument/schema	parameter smuggling, validation bypass	23%
transport hardening	plaintext-transport warning; DNS-rebinding origin <i>enforce</i>	30%
sensitive-arg + least-privilege	cross-tool exfiltration, over-broad scopes	34%
cross-tool correlation	ShareLock split poisoning; MSTI via pinning	38%
new proxy-native checks	command-injection, config-drift, server-identity <i>enforce</i> , cross-server taint	48%
depth cycle	evasion normalization; inline DLP redaction; confidence-tiered enforcement	63%

A living benchmark tracks new attacks. Vectors 23–24 were published *after* the rubric was frozen; adding them exercised the benchmark’s intended lifecycle. Each was verified against its primary source, encoded as a matched malicious/benign pair, and re-run against every tool —

which immediately exposed that ShareLock was covered by none, driving the cross-tool-correlation fix. A benchmark that only measured a fixed attack set would have missed the gap; the value is in re-measuring as the threat surface moves.

From detection to enforcement, and depth over breadth. The last development round did not add vectors but deepened defense of covered ones. Three changes, all re-verified at zero false positives, lifted coverage 48%→63%: (i) *evasion normalization*, running heuristics over NFKC / homoglyph-folded / base64-decoded views so obfuscated payloads are caught the same as plain ones (robustness 1/3→3/3); (ii) *inline DLP redaction*, which strips credential-shaped secret values out of tool results, turning credential-theft and secret-in-fetched-document from detect into an enforcing mitigation; and (iii) a *confidence-tiered enforcement profile* whose default (**balanced**) blocks the deterministic, near-zero-false-positive checks while leaving heuristics as warnings. The result is a proxy that *blocks* 11 of the 19 vectors it covers, not merely warns.

Tool-class taxonomy (what we score vs. what we track). Not every MCP defense is a content-scanning proxy, and scoring all of them on this rubric would mislead. *Content-scanning proxies* (the three we evaluate) inspect tool definitions, calls, or results at runtime; the rubric measures exactly what they inspect, so we **score** them. *Access-control and isolation gateways* enforce identity, policy, and sandboxing rather than scanning content; the rubric’s content-borne vectors would score them near zero not because they are weak but because they operate on a different axis. We **track** these in the landscape without assigning a score, and note that a class-appropriate enforcement-and-isolation rubric is future work.

Corpus-encoding sensitivity (a fairness hazard). Scores are sensitive to how an attack is *encoded*. An early corpus expressed exfiltration with sanitized placeholder text; against it, *mcp-firewall* scored 5%. Adding realistic encodings (an AWS-key-shaped secret in a tool result; an exfiltration POST to the cloud-metadata address) raised it to 13% — not by changing the tool, but by probing capabilities the first corpus never exercised. We therefore treat *tool-neutral*, *realistic*, *multi-encoding* fixtures as a fairness requirement, and caution that absolute totals are corpus-dependent; the per-vector matrix (Table 4) is the more reliable read.

Adapter faithfulness and an automated regression gate. The matched benign control guards against adapter over-reach: while wiring *pipelock* (an egress firewall), an initial adapter synthesized an egress URL from an *inbound* local host, causing it to “block” both cases — surfaced immediately as a false positive and corrected. To keep the benchmark-guided loop honest over time, the reference proxy’s continuous-integration pipeline runs this benchmark on every change and fails the build if measured coverage drops below a floor or any false positive appears. Measurement is thus not a one-off but a standing regression test on the defense.

8 Limitations and Threats to Validity

- **Taxonomy is a synthesis, not a standard.** The 24-vector set consolidates several proposed taxonomies; it is one reviewable synthesis. Framework mappings are indicative, single-author, and pending a second-reviewer pass; OWASP Agentic ASI05–ASI10 labels are unconfirmed.
- **Small, seeded corpus.** Most vectors have 1–2 fixtures. Absolute coverage numbers should be read as lower bounds and are corpus-dependent.

- **Heuristics, not proofs.** The ShareLock check flags the *staging signal* (coordinated share/checksum-style metadata), not the cryptographic split itself; cross-server taint uses exact-token propagation; inline DLP targets known credential shapes. A sufficiently disguised variant can evade each.
- **Partial tool interfaces.** For pipelock we drive its offline URL/egress and response-injection scanners but not its poisoned-description check or full DLP endpoint; its number is a lower bound on total capability.
- **Configuration dependence.** Results depend on each tool’s committed policy; different policies would yield different numbers. The reference proxy’s promoted-to-enforce results reflect its default *balanced* profile.
- **Scope and tool class.** We score locally-deterministic content-scanning proxies; cloud-model defenders and access-control/isolation gateways are out of scope for scoring and are tracked, not scored.
- **Self-evaluation.** The author develops one of the evaluated tools (*mcp-bastion*). The benchmark is vendor-neutral, drives each tool through its real code, and scores the author’s tool alongside competitors and a null baseline; all code, data, and configurations are public for independent re-measurement.

9 Future Work

Expand the corpus to multiple tool-neutral fixtures per vector and deepen the evasion set; drive the remaining interfaces of evaluated tools and add further defenders (including local modes of cloud-gated gateways, if exposed); complete a second-reviewer pass on framework mappings and confirm ASI labels; define a class-appropriate enforcement-and-isolation rubric for access-control gateways; and build an **attestation-conformance** suite to test tool-integrity/provenance schemes (ETDI, the Trustworthy Registry composition) as a coupled bench-plus-attestation artifact addressing the supply-chain vectors no runtime proxy can reach.

10 Conclusion

We introduced a layer-aware, framework-mapped crosswalk of 24 MCP attack vectors — mapped to the NIST AI RMF, the NSA MCP Security guidance, the OWASP LLM and Agentic Top 10s, and STRIDE — and an open, vendor-neutral benchmark that measures how much of that surface a defensive proxy actually covers, driving each tool through its real code. The strongest of three open-source proxies reaches 63% weighted coverage with 11 vectors enforced, and 5 of 24 vectors are undefended by any measured tool — the registry/supply-chain, OS-isolation, and semantic vectors that lie outside a content-scanning proxy’s reach. The evidence argues for layered defense across distinct mechanism classes, and the benchmark demonstrably guided one proxy from 9% to 63% at zero false positives, tracked two attacks published mid-study, lifted its evasion robustness to 3/3, and is now enforced as a standing regression gate. It provides a reusable, honest instrument — with matched benign controls, a runtime-integrity rule, a reproducibility rule, and automated regression — for the community to measure MCP defenders and track their progress as the threat surface evolves.

Availability

- **Benchmark (mcp-defense-bench):** rubric, corpus, adapters, runner, leaderboard. Rubric/data CC-BY-4.0; harness Apache-2.0. <https://github.com/Gowthaman90/mcp-defense-bench>; archived on Zenodo, DOI 10.5281/zenodo.21346206 [4].
- **Reference proxy (mcp-bastion):** Apache-2.0; published on npm. <https://github.com/Gowthaman90/mcp-bastion> [3].
- **Preprint:** Figshare DOI 10.6084/m9.figshare.32978657.
- Evaluated third-party tools are used under their own licenses and are not redistributed here.

Reproducibility

All fixtures are static data with reserved, non-routable hosts; no live exploits and no real systems are attacked. Each tool is pinned to a released version with a committed configuration. The runner, scorer, and per-tool coverage outputs are in the repository, and the reference proxy’s CI re-runs the benchmark on every change.

References

- [1] Nirajan Acharya and Gaurav Kumar Gupta. A formal security framework for MCP-based AI agents: Threat taxonomy, verification models, and defense mechanisms. *arXiv preprint arXiv:2604.05969*, 2026. URL <https://arxiv.org/abs/2604.05969>.
- [2] Anthropic and the MCP community. Model context protocol specification. <https://modelcontextprotocol.io/specification>, 2025.
- [3] Gowthaman Arumugam. mcp-bastion: A reliability and security proxy for the model context protocol. <https://github.com/Gowthaman90/mcp-bastion>, npm: mcp-bastion, 2026.
- [4] Gowthaman Arumugam. mcp-defense-bench: A layer-aware, framework-mapped benchmark for model context protocol security proxies. <https://github.com/Gowthaman90/mcp-defense-bench>, 2026.
- [5] Manish Bhatt, Vineeth Sai Narajala, and Idan Habler. ETDI: Mitigating tool squatting and rug pull attacks in model context protocol (MCP) by using OAuth-enhanced tool definitions and policy-based access control. *arXiv preprint arXiv:2506.01333*, 2025. URL <https://arxiv.org/abs/2506.01333>.
- [6] Shiva Gaire, Srijan Gyawali, Saroj Mishra, Suman Niroula, Dilip Thakur, and Umesh Yadav. Systematization of knowledge: Security and safety in the model context protocol ecosystem. *arXiv preprint arXiv:2512.08290*, 2025. URL <https://arxiv.org/abs/2512.08290>.
- [7] Charoes Huang, Xin Huang, Ngoc Phu Tran, and Amin Milani Fard. Model context protocol threat modeling and analyzing vulnerabilities to prompt injection with tool poisoning. *arXiv preprint arXiv:2603.22489*, 2026. URL <https://arxiv.org/abs/2603.22489>.
- [8] Lin-Fa Lee, Yi-Yu Chang, Chia-Mu Yu, and Kuo-Hui Yeh. WebMCP tool surface poisoning: Runtime manipulation attacks on LLM agents. *arXiv preprint arXiv:2606.06387*, 2026. URL <https://arxiv.org/abs/2606.06387>.

- [9] Liwei Liu, Tianzhu Han, Zijian Liu, Zishu Dong, and Na Ruan. ShareLock: A stealthy multi-tool threshold poisoning attack against MCP. *arXiv preprint arXiv:2606.27027*, 2026. URL <https://arxiv.org/abs/2606.27027>.
- [10] L. Mas, J. Vilaplana, J. Rius, R. Spaimoc, and J. Mateo. The trustworthy model context protocol (MCP) registry: An architectural blueprint for cryptographic provenance and runtime integrity. *Future Internet*, 18(5):243, 2026. doi: 10.3390/fi18050243.
- [11] Microsoft. STRIDE threat modeling. <https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats>, 2009.
- [12] National Institute of Standards and Technology. Artificial intelligence risk management framework (AI RMF 1.0). Technical Report NIST AI 100-1, U.S. Department of Commerce, 2023. URL <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf>.
- [13] National Security Agency, AI Security Center. MCP security: Security design considerations for AI-driven automation. Technical Report U/OO/6030316-26, NSA Cybersecurity Information Sheet, 2026. URL https://www.nsa.gov/Portals/75/documents/Cybersecurity/CSI_MCP_SECURITY.pdf.
- [14] OWASP GenAI Security Project. OWASP top 10 for agentic applications, 2026. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>, 2025. Published Dec. 9, 2025; categories ASI01–ASI10.
- [15] OWASP GenAI Security Project. OWASP top 10 for LLM applications, 2025 edition. <https://genai.owasp.org/llm-top-10/>, 2025.
- [16] Mehrdad Rostamzadeh, Sidhant Narula, Nahom Birhan, Mohammad Ghasemigol, and Daniel Takabi. MCP-DPT: A defense-placement taxonomy and coverage analysis for model context protocol security. *arXiv preprint arXiv:2604.07551*, 2026. URL <https://arxiv.org/abs/2604.07551>.
- [17] A. Sanna. AgentDefense-Bench. open-source dataset, GitHub, 2025.
- [18] Snyk. agent-scan (formerly invariant labs MCP-scan). vendor tooling / GitHub, 2026.
- [19] Z. Wang, Q. Chang, H. Patel, S. Biju, C.-E. Wu, Q. Liu, A. Ding, A. Rezazadeh, A. Shah, Y. Bao, and E. Siow. MCP-Bench: Benchmarking tool-using LLM agents with complex real-world tasks via MCP servers. *arXiv preprint arXiv:2508.20453*, 2025. URL <https://arxiv.org/abs/2508.20453>.
- [20] Z. Wang, Y. Gao, Y. Wang, S. Liu, H. Sun, H. Cheng, G. Shi, H. Du, and X. Li. MCP-Tox: A benchmark for tool poisoning attack on real-world MCP servers. *arXiv preprint arXiv:2508.14925*, 2025. URL <https://arxiv.org/abs/2508.14925>.
- [21] D. Zhang, Z. Li, X. Luo, X. Liu, P. Li, and W. Xu. MCP security bench (MSB): Benchmarking attacks against model context protocol in LLM agents. *arXiv preprint arXiv:2510.15994*, 2025. URL <https://arxiv.org/abs/2510.15994>. ICLR 2026.